

NARRATIVA EXPLICATIVA

Del Marco DREAD al Instrumento GQM+PRAGMATIC: Un Relato de Trazabilidad y Rigor

Cómo se midió lo que se midió, por qué se eligió así y qué hacer con los resultados

"Los datos no hablan solos. Los datos necesitan un narrador con conocimiento del terreno, algo de valentía para decir lo incómodo y, si es posible, un buen sentido del humor ante la adversidad estadística."

I. EL ORIGEN: ¿POR QUÉ DREAD NECESITA GQM?

El modelo DREAD nació en los laboratorios de Microsoft como una herramienta pragmática para que los equipos de seguridad priorizaran vulnerabilidades con un criterio más matizado que el viejo "¿es grave? sí/no". Sus cinco dimensiones —Daño, Reproducibilidad, Explotabilidad, Usuarios afectados y Descubribilidad— capturan el riesgo en sus vectores más relevantes: impacto, facilidad de ataque y alcance poblacional.

Sin embargo, DREAD presenta un déficit estructural que los investigadores académicos identificaron pronto: **es un modelo de estimación cualitativa disfrazado de cuantitativo**. Un analista puntúa "Explotabilidad = 8" basándose en su experiencia y criterio profesional, lo que hace que dos analistas diferentes puedan llegar a puntuaciones distintas para la misma vulnerabilidad. Esto no es un problema cuando DREAD se usa para la gestión interna de vulnerabilidades en un equipo bien coordinado. Es un problema grave cuando se pretende usar para comparar el estado de ciberseguridad entre organizaciones, sectores o países.

Y aquí entra la metodología GQM con una pregunta aparentemente sencilla pero filosóficamente potente: **¿de qué objetivo estás hablando exactamente cuando puntúas DREAD?** Porque si el objetivo de la puntuación "Daño = 9" es "evaluar el impacto económico esperado en 12 meses", eso es una pregunta diferente de "evaluar cuántos sistemas quedarían comprometidos", que a su vez es diferente de "evaluar la probabilidad de una notificación obligatoria a la AEPD". Todas son facetas del "Daño", pero requieren métricas diferentes y conducen a decisiones diferentes.

El marco GQM+PRAGMATIC no reemplaza la puntuación DREAD original. La **precisa, la contextualiza y la hace trazable** desde los objetivos estratégicos nacionales hasta el dato técnico más granular.

II. LA ARQUITECTURA DE TRAZABILIDAD: DE LA ESTRATEGIA NACIONAL AL DATO TÉCNICO

El presente marco construye una cadena de trazabilidad de cuatro eslabones:

Estrategia Nacional de Ciberseguridad (ENC 2019-2025)

↓ ancla mediante

Objetivos Nacionales (ON-1 a ON-6)

↓ se concretan en

Metas GQM por dimensión DREAD (D.G1, R.G1, E.G1, A.G1, Disc.G1)

↓ se articulan mediante

Preguntas GQM (D.Q1...D.Q5, R.Q1...R.Q4, etc.)

↓ se responden con

Métricas cuantitativas (D.M1...Disc.M4) con fórmula, fuente, frecuencia y umbral

↓ se evalúan con

Criterios PRAGMATIC (9 criterios × 0-10 puntos cada uno = puntuación 0-90)

Esta arquitectura permite que cuando el CISO presenta al Consejo de Administración la métrica "ALE = 2,3 M€" (D.M1), el Consejo pueda preguntar "¿qué pregunta responde eso?" (D.Q1: ¿cuál es la pérdida financiera esperada si se materializa la amenaza crítica?) y "¿a qué objetivo nacional contribuye?" (ON-1: reducir el impacto económico de los ciberincidentes) y "¿cumple con los requisitos de DORA?" (sí, DORA Art.6 exige análisis de impacto financiero).

Esto puede parecer burocrático. Y lo es, en el mejor sentido de la palabra: es la burocracia que mantiene honesto al proceso de medición y evita que las métricas de ciberseguridad se conviertan en un "teatro de la seguridad" cuantificado.

III. EL MÉTODO PRAGMATIC COMO FILTRO DE CALIDAD

Una de las tentaciones recurrentes en los programas de métricas de ciberseguridad es la "inflación de indicadores": si tener 10 métricas es bueno, tener 50 debe ser mejor. La realidad es exactamente la contraria. Cuantas más métricas, mayor es la carga operativa de recogerlas, mayor el ruido en el análisis y menor la probabilidad de que la dirección preste atención a cualquiera de ellas.

El método PRAGMATIC actúa como un riguroso juez de admisión. Ante cada candidata a métrica, hace nueve preguntas incómodas que la mayoría de los "dashboards de seguridad" jamás se hacen:

- ¿Predice algo útil o solo describe lo que ya ocurrió?
- ¿Genera una decisión o solo documenta el estado actual?
- ¿El dato que usas es real o es el dato que alguien decidió registrar porque era favorable?
- ¿Cuesta más recogerlo que el valor que aporta?

En el análisis de las 23 métricas del set DREAD, el resultado más revelador no es la puntuación máxima (E.M2/TCKEV con 85/90) sino la puntuación mínima en el criterio de Genuinidad (G) en métricas como D.M2, E.M5 y A.M5: todas ellas puntúan 5/10 en G porque dependen de la calidad del inventario de activos (CMDB), que en la inmensa mayoría de las organizaciones está incompleto, desactualizado o directamente ausente.

Este hallazgo tiene una implicación estratégica directa: antes de implantar un programa de métricas DREAD sofisticado, la prioridad cero es tener un inventario de activos actualizado y automatizado. Sin ello, las métricas más elaboradas son castillos en el aire.

IV. LOS CINCO GRUPOS DE MÉTRICAS POR COMPORTAMIENTO PRAGMATIC

El análisis de las puntuaciones PRAGMATIC revela cinco familias de comportamiento distintas:

Grupo 1: Métricas de Tiempo Real y Alta Densidad de Valor (75-85 puntos)

E.M2 TCKEV, R.M2 TVER, Disc.M1 RSAE, R.M1 MTTR, E.M4 TMCE, A.M3 TMNU, A.M1 UMPA, R.M4 VEE, D.M5 TMCD, D.M3 RTO gap

Características comunes: se calculan automáticamente desde sistemas ya desplegados, tienen fuentes autoritativas externas (CISA KEV, NVD, FIRST EPSS), y generan decisiones inmediatas y concretas. Son el núcleo irrenunciable del programa de métricas. El coste de no implantarlas es sistemáticamente mayor que el coste de implantarlas.

Grupo 2: Métricas de Alto Valor con Dependencias Estructurales (63-74 puntos)

Disc.M4 TMDE, D.M1 ALE, Disc.M3 NSIE, A.M5 CCUC, Disc.M2 RDPR, E.M1 SMEC, E.M5 ICCAE, R.M3 ICEP

Características comunes: alta relevancia estratégica pero con dependencia de inversiones estructurales previas (CMDB, BCP, gestión de configuración). Se adoptan en la Fase 2 del roadmap, una vez que las estructuras de soporte están en marcha.

Grupo 3: Métricas de Cumplimiento Regulatorio (58-65 puntos)

D.M2 IEAC, D.M4 TBNO

Características comunes: imprescindibles para el cumplimiento de NIS2, GDPR y ENS, aunque su valor analítico intrínseco es moderado. Se adoptan por imperativo regulatorio, no por su poder predictivo.

Grupo 4: Métricas Financieras Post-Incidente (55-62 puntos)

A.M4 CUA, A.M2 IUVA

Características comunes: alta significatividad para la alta dirección, pero baja oportunidad y alta dificultad de implementación. Útiles para el análisis post-incidente y para calibrar la justificación económica del programa de seguridad.

Grupo 5: Métricas Emergentes de Alta Incertidumbre (55-65 puntos)

E.M3 DREAD-E LLM

Características comunes: alta relevancia futura pero baja madurez metodológica actual. Se adoptan de forma exploratoria con revisión anual de la metodología de evaluación.

V. CÓMO INTERPRETAR LOS RESULTADOS DE LA EVALUACIÓN: DIEZ PRINCIPIOS

1. Una métrica con puntuación PRAGMATIC < 45 no es una métrica; es un gasto operativo disfrazado de seguridad. Descártala sin culpa.
2. El criterio G (Genuinidad) es el voto de veto. Una métrica que puntúa < 4 en G no puede compensarse con puntuaciones altas en los demás criterios: un dato manipulado o inverificable contamina todo el análisis, independientemente de cuán relevante o oportuno sea.
3. Las métricas de tiempo/velocidad (TMCD, MTTR, TMCE, TMNU) son las más accionables del set porque tienen un denominador natural (horas, días) que cualquier stakeholder comprende, y porque el comportamiento a mejorar es inmediatamente identificable: "reducir el tiempo".
4. Combinar CVSS + EPSS + CISA KEV no es redundante, es multiplicativo. CVSS dice cuán severa es la vulnerabilidad técnicamente; EPSS dice cuán probable es que alguien la explote en los próximos 30 días; KEV dice que alguien ya la está explotando ahora mismo. Las tres preguntas son distintas y complementarias.
5. Un score DREAD agregado sin descomposición por dimensiones es un promedio de ruido. Los cinco indicadores DREAD no deben sumarse en un único score general sin ponderar: una vulnerabilidad con Daño=10 y Descubribilidad=2 es radicalmente diferente de una con Daño=6 y Descubribilidad=6, aunque ambas sumen 12 en los dos criterios relevantes.
6. El benchmark sectorial es imprescindible para interpretar las métricas absolutas. Un MTTR de 15 días puede ser excelente en un sector financiero con alta presión regulatoria o desastroso en un fabricante de software con obligación CRA. Sin benchmark, el número no dice nada.
7. Las métricas DREAD son un mapa, no el territorio. El territorio es el perfil de amenazas real de la organización. El mapa debe actualizarse cuando el territorio cambia (nuevas amenazas, nuevos activos, nuevas regulaciones).
8. El silencio de una métrica también es información. Si el TMDE es cero (tiempo de detección externa = cero días), no es porque la organización sea perfecta: puede ser porque no tiene herramienta ASM y simplemente no mide.

9.

Las métricas de usuarios afectados (UMPA, TMNU) son las que más importan al regulador. En caso de incidente, la AEPD y el CNCS mirarán primero cuántos ciudadanos se vieron afectados y en cuánto tiempo se les notificó. Estas dos métricas son la "nota" del examen regulatorio.

10.

La madurez del programa de métricas se mide por cuántas se han dejado de medir —porque se han automatizado y están integradas en el proceso operativo— y no por cuántas se han añadido al dashboard.

Una métrica con puntuación PRAGMATIC < 45 no es una métrica; es un gasto operativo disfrazado de seguridad. Descártala sin culpa.

El criterio G (Genuinidad) es el voto de veto. Una métrica que puntúa < 4 en G no puede compensarse con puntuaciones altas en los demás criterios: un dato manipulado o inverificable contamina todo el análisis, independientemente de cuán relevante o oportuno sea.

Las métricas de tiempo/velocidad (TMCD, MTTR, TMCE, TMNU) son las más accionables del set porque tienen un denominador natural (horas, días) que cualquier stakeholder comprende, y porque el comportamiento a mejorar es inmediatamente identificable: "reducir el tiempo".

Combinar CVSS + EPSS + CISA KEV no es redundante, es multiplicativo. CVSS dice cuán severa es la vulnerabilidad técnicamente; EPSS dice cuán probable es que alguien la explote en los próximos 30 días; KEV dice que alguien ya la está explotando ahora mismo. Las tres preguntas son distintas y complementarias.

Un score DREAD agregado sin descomposición por dimensiones es un promedio de ruido. Los cinco indicadores DREAD no deben sumarse en un único score general sin ponderar: una vulnerabilidad con Daño=10 y Descubribilidad=2 es radicalmente diferente de una con Daño=6 y Descubribilidad=6, aunque ambas sumen 12 en los dos criterios relevantes.

El benchmark sectorial es imprescindible para interpretar las métricas absolutas. Un MTTR de 15 días puede ser excelente en un sector financiero con alta presión regulatoria o desastroso en un fabricante de software con obligación CRA. Sin benchmark, el número no dice nada.

Las métricas DREAD son un mapa, no el territorio. El territorio es el perfil de amenazas real de la organización. El mapa debe actualizarse cuando el territorio cambia (nuevas amenazas, nuevos activos, nuevas regulaciones).

El silencio de una métrica también es información. Si el TMDE es cero (tiempo de detección externa = cero días), no es porque la organización sea perfecta: puede ser porque no tiene herramienta ASM y simplemente no mide.

Las métricas de usuarios afectados (UMPA, TMNU) son las que más importan al regulador. En caso de incidente, la AEPD y el CNCS mirarán primero cuántos ciudadanos se vieron afectados y en cuánto tiempo se les notificó. Estas dos métricas son la "nota" del examen regulatorio.

La madurez del programa de métricas se mide por cuántas se han dejado de medir —porque se han automatizado y están integradas en el proceso operativo— y no por cuántas se han añadido al dashboard.

VI. EL CONTEXTO ESPAÑOL: PECULIARIDADES Y OPORTUNIDADES

El marco regulatorio como catalizador

España ocupa en 2025-2026 una posición privilegiada en el ecosistema regulatorio europeo: la transposición de NIS2 mediante la Ley de Coordinación y Gobernanza de la Ciberseguridad (LCGC-2025), la aplicación directa de DORA para el sector financiero desde enero de 2025 y la entrada en vigor progresiva del Cyber Resilience Act crean un mandato regulatorio que actúa como catalizador involuntario de la adopción de métricas. Las organizaciones que se habían resistido durante años a implantar indicadores cuantitativos de ciberseguridad ahora tienen la motivación (o la obligación) de hacerlo.

El papel de INCIBE como ancla del ecosistema de métricas

El Marco de Indicadores de Ciberresiliencia (IMC) de INCIBE proporciona un vocabulario y una taxonomía de referencia que facilita la comparación entre organizaciones españolas. El presente marco GQM+PRAGMATIC es deliberadamente compatible con el IMC: las métricas propuestas pueden mapearse directamente a las categorías del IMC, lo que permite que las organizaciones que ya informan al INCIBE puedan adoptar el marco sin duplicar el esfuerzo de reporte.

La amenaza de la fragmentación sectorial

El principal riesgo en el ecosistema español de métricas es la **fragmentación**: cada organización desarrolla sus propias definiciones de MTTR, sus propias escalas DREAD y sus propios umbrales, lo que hace imposible la comparación sectorial que los reguladores necesitan para diseñar políticas eficaces. El presente marco propone definiciones precisas y fuentes de datos estandarizadas (NVD, FIRST EPSS, CISA KEV, CMDB ISO) precisamente para reducir esta fragmentación.

VII. EL PRINCIPIO EPISTEMOLÓGICO SUBYACENTE

Todo el marco descansa sobre un principio epistemológico que vale la pena explicitar: **la objetividad de una métrica de ciberseguridad no es una propiedad de los datos, sino de las definiciones, los procesos y las fuentes.**

Una métrica "genuina" ($G \geq 8$ en PRAGMATIC) no lo es porque los datos sean perfectos: lo es porque las definiciones son claras, las fuentes son verificables, los procesos de recogida son auditables y los datos no pueden ser manipulados sin dejar rastro. Este es el estándar al que deben aspirar los programas de métricas de ciberseguridad en 2025-2026, no solo en España sino en cualquier organización que tome en serio la gobernanza de su postura de seguridad.

Porque, como alguien dijo con más gracia de la que merece la ocasión, **"lo que no se puede medir no se puede mejorar, pero lo que se mide mal se mejora en la dirección equivocada"**. Y eso, en ciberseguridad, puede ser exactamente tan costoso como no medirlo.

Narrativa Explicativa · Documento C del Kit GQM+PRAGMATIC DREAD · Abril 2026

Fuentes metodológicas: GQM — Basili et al. (1994); PRAGMATIC — Brothby & Hinson (2013)

Contexto normativo: LCGC-2025, NIS2 (Directiva 2022/2555/UE), DORA (Reglamento 2022/2554/UE), ENS